Designing Account-Free Booking Systems: Trade-offs Between Usability, Privacy, and Security

Fjodor Joss
fjjo0001@student.umu.se

August 18, 2026

Examiner: Thomas Mejtoft
Supervisor: Ole Norberg
External Supervisor: Oskar Lundberg, Colorama Umeå
Master's thesis, 30 ECTS
Master of Science in Interaction Technology and Design, 300 ECTS
Department of Applied Physics and Electronics
Umeå University, Sweden

Abstract

Modern commercial systems typically utilize user accounts to store personal information, which aids in functionality, administration, and management. However, there has been limited research on how account-free architectures influence the relationship between usability, privacy, and security in these systems. While user accounts facilitate traceability and personalization, they also introduce challenges related to privacy, security, and increased complexity in user interactions.

This study investigates how a booking system can be designed without the need for user accounts, examining the implications for system design and user interaction processes. The research was conducted in collaboration with a local paint and decorating retailer that provides tool and equipment rentals as an additional service.

Following User-Centered Design principles, a web-based booking system was developed using React, .NET, and PostgreSQL. Usability was evaluated through interviews, observations, and scenario-based user testing with both employees and public users. Security and privacy concerns were addressed through literature research, architectural analysis, qualitative risk assessments, and threat modeling using OWASP Threat Dragon.

The final system differentiated between public booking functionality and administrative functions, eliminating the requirement for user accounts by implementing token-based booking management. This approach enabled customers to retain control while minimizing the collection of personal data. The results indicated that reducing authentication requirements and simplifying workflows improved accessibility and reduced interaction friction. Key design and security features included architectural separation, audit logging, automated personal data management, and backend validation, supporting operational control and protecting customer data.

The study identified several trade-offs between usability, privacy, and security in the booking system. While the simplified workflows and reduced authentication requirements improved usability and data minimization, they also increased reliance on alternative control mechanisms, such as booking tokens, administrative oversight, and server-side validation. The findings suggest that account-free booking systems can achieve both usability and privacy-oriented objectives if the design effectively incorporates architectural and organizational measures to address risks related to accountability, misuse prevention, and the protection of personal information.

Keywords: Account-Free Booking Systems, User Experience, Privacy by Design, Cybersecurity, GDPR

Sammanfattning

Moderna kommersiella system använder vanligtvis användarkonton för att lagra personuppgifter, vilket underlättar funktionalitet, administration och hantering. Det har dock forskats i begränsad omfattning på hur kontofria arkitekturer påverkar sambandet mellan användbarhet, integritet och säkerhet i dessa system. Även om användarkonton möjliggör spårbarhet och personalisering, medför de också utmaningar kopplade till integritet, säkerhet och ökad komplexitet i användarinteraktioner.

Den här studien undersöker hur ett bokningssystem kan utformas utan behov av användarkonton, samt vilka konsekvenser detta får för systemdesign och användarinteraktion. Forskningen genomfördes i samarbete med en lokal färg- och inredningsbutik som erbjuder uthyrning av verktyg och utrustning som en tilläggstjänst.

Med utgångspunkt i principer för användarcentrerad design utvecklades ett webbaserat bokningssystem med hjälp av React, .NET och PostgreSQL. Användbarheten utvärderades genom intervjuer, observationer och scenariobaserade användartester med både anställda och allmänna användare. Säkerhets- och integritetsaspekter hanterades genom forskningsstudier, arkitekturanalys, kvalitativa riskbedömningar samt hotmodellering med OWASP Threat Dragon.

Det slutliga systemet skiljde mellan publik bokningsfunktionalitet och administrativa funktioner, och eliminerade kravet på användarkonton genom att implementera tokenbaserad bokningshantering. Det här tillvägagångssättet gjorde det möjligt för kunder att behålla kontrollen samtidigt som insamlingen av personuppgifter minimerades. Resultaten visade att minskade autentiseringskrav och förenklade arbetsflöden förbättrade tillgängligheten och minskade friktionen i användarinteraktionen. Centrala design- och säkerhetsfunktioner inkluderade arkitektonisk separation, loggning för spårbarhet, automatiserad hantering av personuppgifter samt validering i backend, vilket stödjer operativ kontroll och skyddar kunddata.

Studien identifierade flera avvägningar mellan användbarhet, integritet och säkerhet i bokningssystemet. Medan förenklade arbetsflöden och minskade autentiseringskrav förbättrade användbarheten och dataminimeringen, ökade de också beroendet av alternativa kontrollmekanismer, såsom bokningstoken, administrativ tillsyn och serverside-validering. Resultaten tyder på att kontofria bokningssystem kan uppnå både användbarhets- och integritetsmål, förutsatt att designen effektivt integrerar arkitektoniska och organisatoriska åtgärder för att hantera risker relaterade till ansvarsskyldighet, förebyggande av missbruk och skydd av personuppgifter.

Definitions and Abbreviations

UX User Experience

UI User Interface

UCD User-Centered Design

GDPR General Data Protection Regulation

PII Personally Identifiable Information

API Application Programming Interface

REST Representational State Transfer

JWT JSON Web Token

HTTPS Hypertext Transfer Protocol Secure

CORS Cross-Origin Resource Sharing

SMS Short Message Service

DBMS Database Management System

SQL Structured Query Language

ORM Object-Relational Mapping

CIA Confidentiality, Integrity, and Availability

OWASP Open Worldwide Application Security Project

STRIDE Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege

Threat Dragon OWASP Threat Dragon threat modeling tool

Contents

1 Introduction **7**

1.1 User Experience Perspective . . . 8
1.2 Security Perspective . . . 8
1.3 Privacy Perspective . . . 8
1.4 Towards an Integrated Perspective . . . 9
1.5 Objective . . . 10
1.6 Research Questions . . . 10
1.7 Scope and Limitations . . . 10

2 Background and Theory **12**

2.1 Booking Systems . . . 12
2.2 Privacy and GDPR . . . 12
2.3 System Architecture . . . 13
2.4 Authentication and Identity Management . . . 15
2.5 Threat Modeling and Risk Analysis . . . 16
2.5.1 OWASP Threat Dragon . . . 17
2.6 User-Centered Design . . . 18
2.7 Usability Principles and Interaction Friction . . . 18
2.8 Personal Data Collection in Web Systems . . . 19

3 Method **21**

3.1 Case Description . . . 21
3.2 Field-Based Approach . . . 21
3.3 User Experience Method . . . 22
3.3.1 Research Design - User Experience . . . 22
3.3.2 Participants and Sampling - User Experience . . . 23
3.3.3 Materials and Apparatus - User Experience . . . 24
3.3.4 Procedure . . . 25
3.3.5 Data Analysis - User Experience . . . 26
3.4 Security and Privacy Method . . . 26
3.4.1 Research Design - Security and Privacy . . . 27
3.4.2 Materials and Apparatus - Security and Privacy . . . 28
3.4.3 Procedure - Security and Privacy . . . 28
3.4.4 Data Analysis - Security and Privacy . . . 28

4 Results **29**

4.1 User Experience . . . 29
4.1.1 Initial Interview and Requirement Gathering . . . 29
4.1.2 Early Prototype Evaluation . . . 29

4.1.3 Final User Testing . . . 32
4.2 Security and Privacy . . . 34
4.2.1 Public Booking Functionality . . . 35
4.2.2 External Communication Services . . . 36
4.2.3 Administrative Access and Traceability . . . 37
4.2.4 Personal Data Handling and Life-Cycle Management . . . 37
4.2.5 Architectural Separation . . . 37
4.2.6 Observed Trade-offs . . . 38

5 Discussion **40**
5.1 Privacy-Oriented System Design . . . 40
5.2 Usability and Reduced Interaction Friction . . . 40
5.3 Security, Accountability, and Architectural Control . . . 41
5.4 Trade-offs Between Usability, Privacy, and Security . . . 42
5.5 Methodological Reflection . . . 43
5.6 Limitations . . . 44
5.7 Future Work . . . 44

6 Conclusion **46**

A Appendix: Complete Risk Assessment Results **49**

B Appendix: Användarutvärdering **50**

C Appendix: Tematisk Analys **53**

1 Introduction

Modern web-based services commonly rely on user accounts for the long-term storage of personal data. This data is used to support personalization and administrative control. While account-based approaches provide traceability and enable advanced functionality, they also introduce challenges related to privacy, security, and interaction complexity [17, 3]. Users are often required to create accounts, manage credentials, and share personal information, even in situations where the interaction itself is temporary [3]. Such practices may also increase organizational responsibilities regarding the handling of personal data under GDPR [23].

The European Union (EU) introduced regulations through the General Data Protection Regulation (GDPR), which established stricter requirements for the collection, processing, and storage of personal data [23]. Systems that handle unnecessary personal information increase both privacy risks and organizational responsibilities related to data protection, security management, and regulatory compliance [23].

These challenges are also visible in commercial booking systems. Most users expect booking processes to be fast, simple, and accessible [20], while organizations still require operational control and reliable management of reservations and customer information [9]. Reducing interaction friction may weaken security mechanisms, whereas stricter authentication and privacy controls may increase complexity and reduce accessibility [2, 3].

Reducing the reliance on user authentication introduces new challenges related to accountability, misuse prevention, traceability, and administrative control [9]. When traditional identity-based mechanisms are minimized, systems instead become more dependent on alternative architectural safeguards such as backend validation, audit logging, token-based access, and separation between public and administrative functionality [21].

This creates a broader design problem in which usability, privacy, and security cannot be treated as isolated concerns [5]. Instead, these aspects continuously influence one another throughout the development process. By considering them together, it becomes possible to design systems that balance competing requirements rather than optimizing a single aspect in isolation [5].

In this study, these challenges are explored through the design and evaluation of a commercial booking system for tool rental. The system was developed with the goal of minimizing persistent collection of personal data while still maintaining operational functionality, administrative control, and security. The following sections will examine how usability, privacy, and security perspectives are relevant to the design of account-free booking systems.

1.1 User Experience Perspective

According to *The UX Book*, user experience (UX) design focuses on creating systems that feel intuitive and logical [11]. In a booking system, this can involve reducing clicks and using clear workflows to minimize cognitive load for the user. Features such as availability overviews, simplified booking forms, confirmation feedback, and intuitive navigation structures can help users complete tasks efficiently while reducing the risk of errors and confusion [11].

In commercial environments, usability is also important for administrative staff who manage bookings, customer communication, and operational workflows. Administrative interfaces therefore require efficient navigation, rapid access to booking-related functionality, and support for handling multiple tasks simultaneously [11]. From a UX perspective, minimizing friction and simplifying interaction flows are central goals within both customer-facing and administrative parts of the system [11].

1.2 Security Perspective

From a security perspective, booking systems must protect customer information, maintain operational reliability, and prevent unauthorized access or misuse [25, 19]. Modern web applications frequently process sensitive information and expose functionality through publicly accessible interfaces, making them vulnerable to threats such as unauthorized data access, manipulation of booking operations, and abuse of public endpoints [25, 14, 7].

As described by Moschovitis, cybersecurity can be understood as maintaining confidentiality, integrity, and availability within a system [19]. In booking systems, this may involve authentication mechanisms, role-based access control, audit logging, validation of user input, backup protocols, and protection of administrative functionality [7, 4, 14]. Security mechanisms may also introduce additional interaction complexity for users and administrators, particularly when systems rely heavily on authentication and identity verification [2, 11]. An example of this could be forced complex passwords or multi-factor authentication [2].

1.3 Privacy Perspective

Privacy-oriented system design focuses on limiting the collection, storage, and exposure of personal information throughout the system lifecycle [16]. Guarda and Zannone further argue that privacy protection becomes significantly more effective when privacy considerations are integrated early in the design and development process rather than added after system implementation [10].

In booking systems, this includes principles such as data minimization, controlled access

to customer information, retention limitations, and lifecycle management of personal data [16, 13].

An example of a privacy-focused design is a system architecture that automatically removes personal data after use or limits data collection to information that is strictly necessary for the intended purpose [16, 13].

Using this approach within an account-free booking system can reduce privacy risks and organizational responsibility related to personal data handling [16]. However, minimizing reliance on saved customer identity also introduces new design challenges related to accountability, traceability, misuse prevention, and operational control [10, 16].

1.4 Towards an Integrated Perspective

Usability, security, and privacy are often discussed separately or in pairs, but they are closely interconnected within system development [11, 2]. Design decisions intended to improve one aspect frequently influence the others, either positively or negatively [2, 10]. For example, reducing authentication requirements may simplify interaction flows and improve accessibility, while simultaneously weakening accountability and increasing exposure to misuse [7, 14]. Minimizing stored personal data can reduce privacy risks while also limiting traceability, reducing user identifiability, and decreasing administrative oversight [10, 4].

These dependencies become important during system design and development [2, 10]. Without account-based interaction, systems must instead rely on alternative mechanisms to maintain operational control and security [7]. Such mechanisms may include architectural separation between public and administrative functionality, backend validation, temporary booking tokens, and automated life-cycle management of customer information [24, 14, 4, 13].

The balance between these aspects depends highly on context [11]. In the context of commercial tool rental, booking workflows must remain efficient and accessible for customers while still supporting operational requirements such as reservation management, equipment tracking, and handling of customer-related information. The system must therefore balance low-friction interaction with sufficient protection against misuse and unauthorized access [2, 11].

Understanding how these trade-offs can be managed is central to the design of booking systems that aim to step away from long-term storage of personal data while still maintaining functionality and operational reliability [12]. This study investigates how usability, privacy, and security can be integrated within an account-free booking system architecture and how architectural decisions influence the relationship between these competing requirements.

1.5 Objective

The objective of this thesis is to investigate how a commercial booking system can minimize reliance on user accounts and long-term storage of personal data while maintaining usability, operational functionality, and administrative control.

The study explores how account-free interaction and privacy-oriented design approaches influence system usability, security, accountability, and handling of customer information. The study has a high focus on architectural mechanisms, such as backend validation, booking tokens, life-cycle management, and separation between public and administrative functionality.

To investigate these aspects in practice, a prototype booking system was designed, implemented, and evaluated through the whole process with user tests, architectural analysis, and qualitative threat modeling.

The overall goal of the thesis is to contribute design-oriented insights into how usability, privacy, and security can be balanced within booking systems designed to reduce dependency on user accounts.

1.6 Research Questions

Based on the identified challenges, the study is guided by the following research questions:

1. How can a booking system be designed to minimize personal data collection while maintaining required functionality and administrative control?

2. What trade-offs arise between user experience, privacy, and security in a booking system with reduced reliance on user accounts?

1.7 Scope and Limitations

This study focuses on the design and prototype implementation of a commercial booking system for tool rental, with an emphasis on minimizing personal data collection and reducing reliance on user authentication.

The system is implemented using a web-based architecture consisting of a .NET backend and a React frontend. These technologies are selected as one of several possible implementation approaches and serve as a basis for exploring the design concepts presented in this study.

The work primarily addresses design and architectural considerations related to the integration of user experience, privacy, and security. The evaluation is conducted in a controlled setting and focuses on system functionality, interaction design, and administrative

workflows.

The study does not include large-scale deployment, long-term user studies, or formal security testing such as penetration testing. Additionally, while the system is designed with GDPR principles in mind, it does not constitute a legally validated or certified solution. The booking system implemented does not handle payments; customers pay in the store when the equipment is retrieved.

The findings should therefore be interpreted as design-oriented insights rather than fully validated results for production environments.

2 Background and Theory

The theoretical background and related concepts relevant to this study. The theories selected in this chapter work together in these areas to provide the foundation for analyzing and understanding how usability, privacy, and security can be balanced within an account-free booking system.

2.1 Booking Systems

Booking systems are used to manage reservations of shared resources, e.g., rooms, tools, or equipment. Their primary purpose is to coordinate availability, prevent scheduling conflicts, and support efficient workflows.

Booking systems can rely on manual processes such as reservation lists, notice boards, paper schedules, or even physical booking tokens. The approach depends heavily on trust, convenience, and operational needs. As digital systems became more common, electronic booking platforms replaced many manual workflows by automating reservation handling, availability management, and conflict prevention [24].

Web-based systems additionally support remote access, and a wide range of options for personalizing the system to the workflow [24]. These capabilities allow booking platforms to automate a large section of the reservation workflows, hence improving User Experience (UX) for customers and administrators [11, 24].

Account-based approaches provide operational benefits it also introduce additional interaction steps and increase organizational responsibility regarding personal data handling. In many booking scenarios, user interactions are temporary or transactional in nature, making long-term identity management redundant. This, together with GDPR, has contributed to an increase in systems designed for low-friction interactions, removing account creation and at the same time minimizing the collection of personal data [11, 10, 23].

This makes booking systems particularly relevant for studying the relationship between usability, privacy, and security. Simplified interaction flows may improve accessibility and reduce cognitive load, while user accounts may strengthen accountability and administrative control [11, 2, 4]. Designing a booking system involves balancing competing requirements rather than optimizing a single aspect of system quality [12].

2.2 Privacy and GDPR

The General Data Protection Regulation (GDPR) was introduced by the European Union to strengthen the protection of the individual user's data. Larger tech companies focused on collecting as much data as possible and, at the same time, profiting from the data collected. The act was a way to counter this and increase organizational accountability

regarding how personal information is processed and stored [23, 16]. For web-based systems, GDPR has increased the importance of limiting unnecessary data collection and ensuring that personal information is managed responsibly throughout its life-cycle.

Several GDPR principles are particularly relevant in booking systems [23, 16]:

- **Data minimization:** Systems should only collect personal data necessary for completing and managing bookings [23].
- **Purpose limitation:** Collected information should only be processed for clearly defined operational purposes [23].
- **Storage limitation:** Personal data should not be retained longer than necessary [23].

These principles create challenges for systems that are built around user accounts, but lack a motivated reason to store user data over a long period. User accounts often improve personalization, traceability, and administrative control, but they also increase privacy risks and organizational responsibility related to data protection and regulatory compliance [16, 10].

To address these challenges, privacy-by-design principles emphasize integrating privacy principles directly into system architecture in the development processes, rather than treating privacy as an additional layer on the implementation [10]. Within booking systems, this may involve minimizing the need to store customer data, separating booking data from personally identifiable information, and automatically removing identifiable data after use.

Privacy-oriented approaches may need to avoid user accounts when recurring identification is not operationally necessary. Reducing reliance on stored user identities may introduce new challenges. While account-free interaction can improve accessibility and reduce long-term exposure of personal information, it can lead to weakened traceability, reduce personalization, and require alternative mechanisms for accountability and misuse prevention [2, 4].

Privacy in booking systems cannot be viewed independently from usability and security. Instead, privacy-related design decisions directly influence authentication strategies, administrative workflows, system architecture, and operational control [11, 12].

2.3 System Architecture

System architecture plays an important role in how usability, privacy, and security are balanced within the system. In distributed systems, architectural separation is commonly used to isolate responsibilities between different system components. This reduces unnec-

essary coupling between interfaces, business logic, and persistent data storage [24].

The booking system developed in this study is designed as a layered client-server system where front-end, backend, and database components were separated into different layers. The front-end handles user interaction. The backend manages business logic, validation, authentication, communication with external services(e.g., SMS confirmations), and interaction with the database [24].

Rather than viewing architecture only as a technical implementation detail, architectural separation can also support privacy and security goals. Separating public booking functionality from administrative functionality limits exposure of operations that handle sensitive data and reduces the risk that it becomes accessible through public-facing interfaces. Centralizing validation and authorization logic within backend services can also reduce inconsistencies and improve control over how personal information is processed [7, 14].

Figure 1 illustrates the simplified architecture of creating a booking. The diagram shows how the interaction, backend logic, external services, and database handling were separated into distinct components. This helps to support low friction with high privacy interaction, with all security-related requirements still intact.

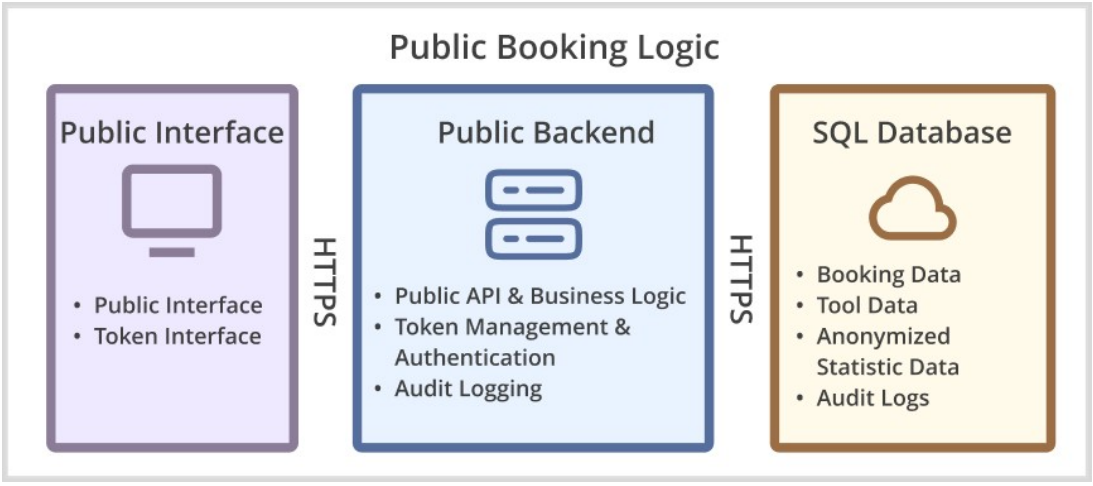


Figure 1: Simplified architecture overview of the public booking system showing communication between the public interface, backend services, and database components.

Communication between system components primarily uses REST-based API with HTTPS security [15]. Within the context of this study, REST based api supports the booking flows, administrative workflows, and communication with external services such as SMS providers. The backend implementation used Entity Framework Core as an object-relational mapping (ORM) framework that provides database abstraction, migration support, and centralized data access mechanisms [18]. These features contribute to maintainability and can reduce common implementation errors when compared to manually

managed database interactions [14]. Previous research comparing database access approaches in .NET environments has shown that Entity Framework can reduce the risk of SQL injection vulnerabilities compared to manually constructed SQL queries [26].

The architecture uses privacy-oriented mechanisms such as automated life-cycle management of customer information, separation of operational booking data from personal data, and centralized handling of validation and access control [13, 10]. Architectural design is closely connected not only to maintainability and scalability, but also to how privacy, accountability, and misuse prevention are implemented in the system [12].

2.4 Authentication and Identity Management

Authentication and identity management influence how functionality, associate actions with users, and manage operational accountability is implemented [9, 14]. In many web-based systems, user accounts are used to connect reservations, permissions, preferences, and administrative operations. This can improve personalization, traceability, and workflow management, particularly in systems involving recurring interactions over time [4, 24].

Account-based interaction also introduces additional complexity due to the need to consider security and privacy features, e.g., password renewal and password handling operations, security surrounding long-term storage [2, 11].

Long-term storage also increases organizational responsibility regarding the protection of personal data. Authentication databases and stored account information may become attractive targets for unauthorized access or identity theft [3, 14].

Alternative approaches to identity management attempt to reduce reliance on user accounts by instead supporting temporary or transactional access models. Such approaches may involve temporary booking links, one-time access tokens, and lightweight identity confirmation. These approaches can simplify interaction flows within the system [10, 11].

Token-based access management is one example of such an approach. In token-based systems, temporary tokens are used to grant limited access to specific resources or functionality without requiring long-term user accounts. Tokens may be time-limited, restricted to specific operations, or to confirmation a email account or phone number [9]. Within booking systems, token-based approaches can support operations such as booking confirmation, cancellation handling, and temporary reservation management while minimizing reliance on persistent user identity.

However, reducing dependence on persistent authentication also introduces challenges related to accountability, misuse prevention, and operational control. As a result, authentication strategies directly influence the balance between usability, privacy, and security within system architecture [12].

2.5 Threat Modeling and Risk Analysis

Threat modeling can be used to identify and analyze potential security threats within a system architecture. If the only focus is on technical vulnerabilities after implementation, many threats can be buried in the system design, hence leading to a more complex process. Threat modeling earlier in the design process attempts to identify risks during system design and development, which allows for proactive decisions regarding security [25].

Threat modeling is commonly used to analyze communication flows, trust boundaries, exposed interfaces, sensitive data handling, and interactions between different system components [25, 22]. The process helps developers identify different risks connected to the specific area.

Several threat modeling methodologies exist, including STRIDE, attack trees, and risk-based architectural analysis. OWASP Threat Dragon is one example of a threat modeling tool designed to support a visual context of the data flows and attack surfaces [22]. Threat modeling tools are frequently used within security-oriented system development, it improves the understanding of how architectural decisions influence the threats [25].

In booking systems, threat modeling helps to identify flaws and risks in the publicly accessible booking flows, authentication mechanisms, and administrative workflows. Systems that expose public interfaces without persistent customer authentication may be particularly vulnerable to risks such as malicious API usage, fake bookings, exposed booking links or user data, unauthorized access to reservation information, and denial-of-service-related misuse [14, 7].

Threat modeling additionally supports analysis of information flows within the system architecture. Visualizing the flow, analyzing exposure points, and evaluating whether appropriate protective is implemented [10, 22].

The findings generated through threat modeling are commonly analyzed in relation to the **CIA Triad**, which describes three central goals within information security [19]:

- **Confidentiality** - Protection against unauthorized access to information.
- **Integrity** - Protection against unauthorized modification of data or system behavior.
- **Availability** - Ensuring that systems and services remain available.

An alternative method is **STRIDE**, which is more focused on identifying and categorizing threats than on defining security goals. STRIDE was developed by Microsoft as a structured threat-modeling framework and classifies threats into six categories [25]:

- **Spoofing** - Impersonating another user, system, or component to gain unauthorized

access.

- **Tampering** - Unauthorized modification of data, code, or system behavior.
- **Repudiation** - Performing actions without sufficient logging or traceability, allowing users to deny their actions.
- **Information Disclosure** - Exposure of information to unauthorized parties.
- **Denial of Service** - Preventing legitimate users from accessing a system or service.
- **Elevation of Privilege** - Gaining permissions beyond those originally granted to a user or process.

While the CIA Triad focuses on the security properties that should be protected, STRIDE provides a systematic approach for identifying threats that may compromise those properties during system design and analysis [25].

Within this study, threat modeling is used as a qualitative analytical method rather than a formal security certification process. The purpose is to identify architectural risks, misuse scenarios, and operational trade-offs related to usability, privacy, and security [12].

2.5.1 OWASP Threat Dragon

OWASP Threat Dragon is an open-source threat modeling tool developed by OWASP to support visualization and analysis of system architectures from a security perspective [22]. The tool is used to model system components, data flows, trust boundaries, and external entities. The model can then be used to identify potential attack surfaces and security risks [25].

Threat Dragon supports threat methodologies such as STRIDE and enables security analysis to be performed throughout or after the development process. By visualizing how information moves between different system components, the tool helps developers reason about confidentiality, integrity, and availability risks throughout the architecture [22, 25].

Within this study, OWASP Threat Dragon was used to model the booking system architecture, including public booking functionality, administrative functionality, database storage, authentication services, and external SMS communication. The threat model was used to identify weak links, exposed interfaces, data flows, and potential misuse scenarios. The model was iteratively updated throughout development and served as an analytical tool for evaluating security and privacy implications of architectural design decisions.

2.6 User-Centered Design

User-Centered Design (UCD) is a development approach that places users at the center of the design process. Rather than focusing solely on technical functionality, UCD emphasizes understanding user goals, behaviors, and workflows [11].

A central principle of UCD is that design decisions should be derived from user interaction. User feedback is collected throughout development and used to refine both functionality and interface design through iterative cycles of design, evaluation, and redesign [11].

According to Hartson and Pyla, UCD aims to improve effectiveness, efficiency, and user satisfaction by ensuring that systems are designed around real user requirements rather than assumptions made by developers [11]. The approach is particularly relevant for systems that support task-oriented activities, such as booking systems, where workflow efficiency and ease of use directly influence the overall user experience.

UCD also recognizes that use differs depending on the user, goals, and interaction patterns. In the context of booking systems, many tasks are repetitive and gain usability when the workflows are optimized. Understanding these differences is important when designing systems that balance usability with organizational requirements [11].

The iterative nature of UCD makes it suitable for exploratory development projects where requirements evolve throughout the design process. The repeated user evaluations constantly inform later design decisions [11].

2.7 Usability Principles and Interaction Friction

Usability describes how effectively, efficiently, and intuitively a system is for a user who wants to complete a process [11]. Within web-based systems, usability is closely connected to clarity, structure, workflow efficiency, consistency, and reduction of unnecessary cognitive load [11].

Nielsen's usability heuristics are commonly used as general principles for identifying usability-related problems within interactive systems [20]. These principles include visibility of system status, consistency and standards, user control and freedom, error prevention, flexibility, and efficiency of use [20]. These heuristics provide a framework for evaluating how well system interfaces support efficient and intuitive interaction.

Within booking systems, usability is particularly important because interactions are often task-oriented and time-sensitive [11]. Users generally expect booking processes to be fast, understandable [11]. Interaction friction refers to obstacles or unnecessary complexity that slow down or interrupt user workflows [2]. Examples may include mandatory account creation, excessive form input, unclear navigation paths, or repetitive interaction steps. In some instances, friction can act as a tool to give the user confidence that the correct

action has been taken, e.g, a pop-up window to confirm booking with a second click.[2, 11].

Reducing friction can improve workflow efficiency by minimizing the steps required to complete booking-related tasks. However, simplified interaction flows may also reduce opportunities for identity verification, confirmation processes, and security-related control mechanisms [2, 3]. As a result, usability-related decisions frequently influence both privacy and security within the system [12].

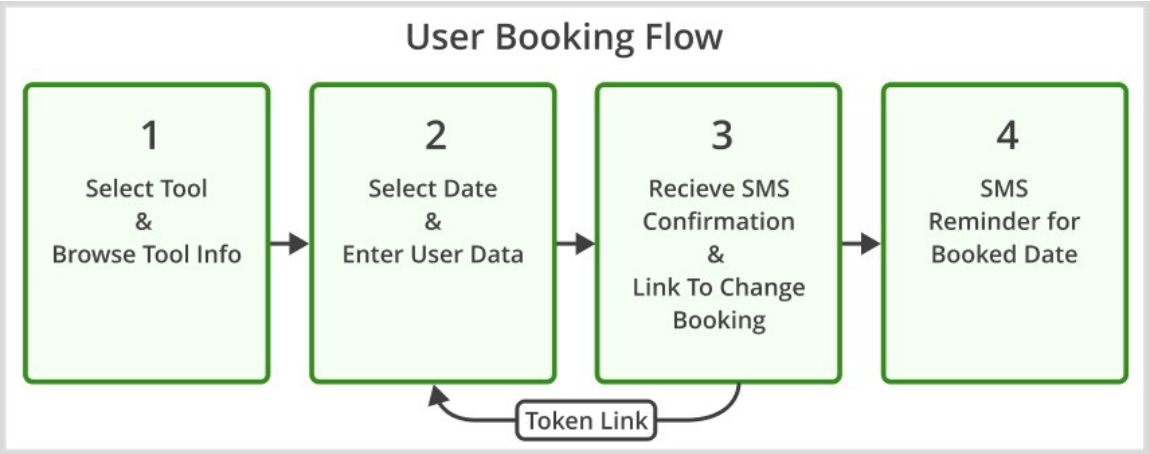


Figure 2: Public booking workflow illustrating the account-free reservation process using SMS-based token management.

Figure 2 illustrates the public booking workflow implemented in the system. The workflow was designed to minimize interaction friction by reducing the number of required interaction steps. Temporary SMS-based booking tokens were used to support account-free booking management while keeping operational functionality.

Administrative usability is heavily influenced by organizational workflows and operational routines [11]. Administrative tasks often follow navigation strategies that depend on work responsibilities, frequency of interaction, and system context. Systems intended for operational use therefore benefit from flexible workflows with multiple access paths to used functionality [11].

Usability cannot be treated independently from system architecture, privacy protection, or security-related design decisions. The interaction design becomes connected to how the system balances accessibility, operational control, and protection of customer information [2, 12].

2.8 Personal Data Collection in Web Systems

Modern web applications frequently process personal information to support authentication, personalization, communication, analytics, and operational management [14, 16].

In booking systems, information may include names, phone numbers, email addresses, reservation details, booking history, payment information, and user activity [16, 10].

This information becomes closely connected to user accounts and long-term identity management [10]. Persistent identities allow systems to provide features such as saved preferences, booking history, personalized recommendations, and long-term customer management [10]. The long-term storage of such information also introduces additional responsibilities regarding data protection and regulatory compliance under GDPR [23].

Different approaches to identity and data management can solve different operational needs while also significantly influencing system architecture and design decisions [10, 12]. Systems based on user accounts may increase personalization, while systems based on temporary interaction or account-free usage may reduce friction and minimize exposure of personal information. However, minimizing stored identity data may also weaken traditional mechanisms for traceability, access control, and user verification [2, 4].

Decisions regarding identity management and data retention directly influence how systems handle accountability, operational control, accessibility, and protection of customer information [12, 10].

3 Method

This study followed a qualitative research approach to investigate how user experience, privacy, and security can be balanced within a booking system with reduced reliance on user data and user accounts. The study did not aim to develop a finished commercial product but to design, implement, and evaluate a functional prototype. The implementation was used to examine how different architectural and interaction-related decisions influenced the relationship between user experience, privacy, and security.

The development process followed principles from User-Centered Design (UCD) [11]. Iterations of development were followed by evaluation, testing, and user feedback. Continuous evaluation provided evidence-based information that informed later design decisions throughout the implementation process [11].

The following methods were used to investigate the system iteratively within a User-Centered Design framework:

- Qualitative user experience evaluation with observed test cases and interviews.
- Architectural analysis with OWASP Threat Dragon.
- Management of privacy and security risks using a version of Informationssakerhet.se's [1] risk assessment tool developed by Linköping University.

The methodological goal was not to produce statistically generalizable results or formally certified security guarantees. Instead, the study aimed to generate design-oriented insights into how account-free booking systems can balance user experience, privacy, and security in practice.

3.1 Case Description

The study was conducted in collaboration with a local paint and decorating retailer that offers rental of tools and equipment as a supplementary business activity. The booking process constitutes a relatively low-frequency operational workflow compared to the company's primary retail activities. This context influenced both usability requirements and organizational preferences regarding administrative account management and workflow efficiency.

3.2 Field-Based Approach

The research process consisted of iterative cycles of development and evaluation. Each phase built on findings from previous cycles, and these findings continuously informed implementation decisions and architectural design. The study combined perspectives

from user experience, privacy-oriented system design, and web application security to investigate how these aspects interact within a single system architecture [11, 10, 14].

The usability perspective focused on workflow efficiency, interaction complexity, and user behavior within both public and administrative booking interfaces. Qualitative methods such as interviews, observations, and scenario-based user testing were selected because the study aimed to explore user interaction patterns and perceived interaction friction rather than produce quantitative usability metrics or scores [11].

The reduction of personal data that followed from removing user accounts led the privacy perspective to focus on how to design the architecture around temporary user data, including how the collection, storage, and life-cycle management of personal data would be handled within the system. GDPR principles and privacy-by-design theory were used as analytical frameworks during both the implementation and evaluation of the system architecture [23, 10]. Privacy concerns were often addressed together with risk analysis and were therefore primarily discussed alongside security.

The security perspective focused on identifying system vulnerabilities, misuse scenarios, and operational risks related to booking functionality, authentication strategies, and handling of customer information. Because the system was evaluated within a prototype and research context rather than as a finished product, the security evaluation emphasized qualitative threat analysis and architectural risk assessment instead of formal penetration testing or quantitative measurements [25, 22]. This approach also allowed for continuous evaluation of early prototypes as well as the implemented design.

The different perspectives were analyzed together throughout the study in order to examine how user experience, privacy, and security were affected. For example, reducing interaction complexity (user experience) could influence accountability (security), administrative control (user experience), and protection of personal data (security and privacy).

3.3 User Experience Method

This section describes the methods used to evaluate the user experience of the booking system. The user experience evaluation focused on workflow efficiency, interaction design, navigation behavior, and reduction of interaction friction within both the public booking interface and the administrative interface.

3.3.1 Research Design - User Experience

The user experience evaluation followed a qualitative approach. It focused on understanding how users interacted with the booking workflows and on identifying usability-related issues connected to navigation, workflow efficiency, interaction clarity, and administrative complexity [11].

The first evaluation phase was carried out through interviews to establish an overview of the research context and to map user workflows within the management section. The initial phase also included a review of similar projects to understand how users typically interact with comparable systems.

The second and third iterations examined the workflows and efficiency of the management system in greater detail, focusing on how employees handled bookings.

The final evaluation was more extensive and was conducted using scenario-based user tests. Observations were added to the tests to gather more detailed information about how users interacted with the system.

3.3.2 Participants and Sampling - User Experience

To reduce the risk of identifying participants from the collaborating company, demographic information such as age and gender was not collected. Given the limited sample size, the study was not intended to support demographic analysis, and any conclusions based on age or similar characteristics would lack validity. Excluding such information also helped to preserve participant anonymity.

The UX evaluation involved two different user groups: administrative users and public users.

Administrative participants consisted of employees at the collaborating company who regularly handled bookings, customer communication, and equipment management. These participants were selected because they possessed contextual knowledge regarding operational workflows and practical booking-related challenges that occur in this company.

The initial research phase included an interview with one employee. The interview focused on identifying operational requirements, existing workflows, and current administrative problems.

The second and third interviews were carried out with a total of six participants. The administrative system was evaluated by two participants from the collaborating company, who assessed the design and workflows. The public interface was evaluated by four participants.

The final evaluation phase was conducted with a total of seven participants. The management system was tested by three participants, while the public booking system was tested by four participants.

Because the study focused on exploratory qualitative evaluation rather than quantitative usability measurement, participant selection prioritized contextual relevance and practical workflow experience over statistical representativeness [11].

The following table provides an overview of all participants involved throughout the study, including the distribution between company participants and public participants across the different evaluation stages (Table 1).

Table 1: Overview of participants involved in the different evaluation stages

Evaluation Stage	**Company Participants**	**Public Participants**	**Total**
Initial Interview	1	0	1
Second and Third Interviews	2	4	6
Final Evaluation Phase	3	4	7
Total Unique Participants	**5**	**8**	**13**

Note: The totals represent unique participants. Some participants may have taken part in more than one evaluation activity.

Table 2 presents the demographic characteristics of the public participants who took part in the usability evaluations. The participants represented a relatively broad age range and included both male and female users.

Table 2: Demographic characteristics of public participants

Characteristic	**Value**
Number of participants	8 (100%)
Women	5 (62.5%)
Men	3 (37.5%)

3.3.3 Materials and Apparatus - User Experience

The primary evaluation material consisted of the implemented booking system prototype, including both the public booking interface and the administrative interface. The computer used for the simulations was the same computer that the collaborating company used for booking operations.

The evaluation additionally used workflow scenarios connected to reservation management, booking creation, cancellation handling, and administrative management of returned equipment.

The complete test scenarios, interview guide, and observation protocol are presented in **Appendix B**.

The initial interview for this project was semi-structured and focused on gathering information about workflows and procedures.

The second and third interviews revolved around following up on the workflows and gathering more specific information on preferred design decisions.

The final interview was designed around the user tests to gather information about the procedure and to clarify observations that were made.

3.3.4 Procedure

The UX process followed User-Centered Design principles, and participant feedback was used to refine the system [11].

The process began with interviews that focused on identifying operational workflows, practical requirements, and usability-related problems within existing booking routines. Based on the collected information, an initial prototype was developed and iteratively refined through prototype evaluations and employee feedback.

Figure 3 illustrates the iterative User-Centered Design process followed throughout the development and evaluation of the booking system.

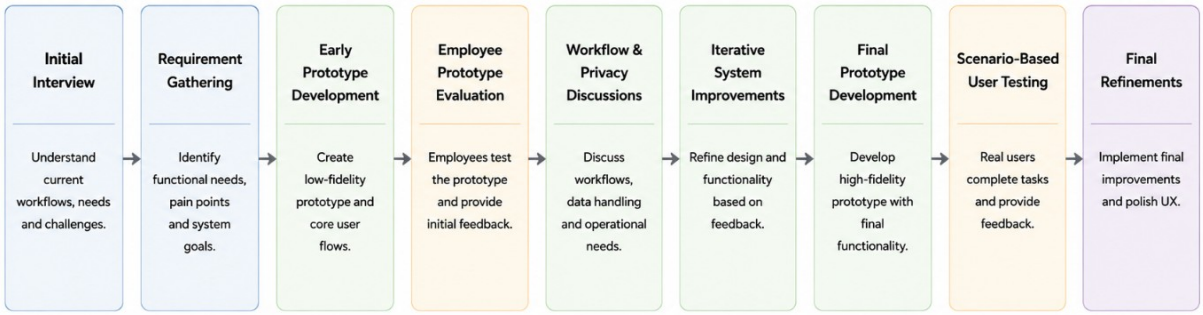


Figure 3: The iterative design process used in this study; it follows the principles of User-Centered Design.

The following two interview sessions were conducted after users had the opportunity to explore the system and test the implemented features. These interviews were semi-structured and consisted primarily of questions related to workflows and implemented functionality. The purpose of the sessions was to ensure that the system's functionality and workflows aligned with the direction of the evolving prototype. They also served as an early evaluation of user interaction and usability.

Evaluating the prototype at an early stage was important because further development would increase the coupling between system components and artifacts. By assessing parts of the system during development, issues related to functionality, design, or workflow disruptions could be identified and addressed before they affected larger portions of the system. This allowed changes to be implemented at lower cost and with reduced impact on other system components.

After implementation of the main system functionality, qualitative user testing was conducted using scenario-based tasks. Administrative users performed tasks related to booking management, reservation handling, and equipment return workflows, while public users performed tasks such as creating and canceling bookings. A detailed description of the scenario-based tasks is provided in **Appendix B**.

During the sessions, observations were made regarding navigation behavior, interaction patterns, workflow efficiency, recurring usability issues, and mismatches between user expectations and implemented system behavior. Semi-structured interviews were additionally conducted after the

testing sessions in order to gather reflections regarding usability, perceived complexity, workflow flexibility, and overall user experience [11].

3.3.5 Data Analysis - User Experience

The user experience evaluation used qualitative thematic analysis based on observations, participant feedback, and interview responses collected during the evaluation sessions.

Recurring usability issues and interaction-related problems were grouped into themes connected to workflow efficiency, navigation clarity, interaction consistency, and administrative complexity. Nielsen's usability principles were additionally used as an interpretive framework during analysis of the identified usability problems [20].

The analysis focused primarily on identifying recurring patterns and workflow-related friction rather than measuring usability performance or task completion speed. Because of the relatively small participant groups and the exploratory nature of the study, the findings should be interpreted as qualitative, design-oriented insights rather than statistically generalizable usability results [6].

3.4 Security and Privacy Method

This section describes the methods, tools, and analytical approaches used to evaluate the security and privacy aspects of the implemented booking system. The central part of the security research and analysis in the study was conducted using visual modeling with the software OWASP Threat Dragon. The architectural threat model presented in Figure 4 supported the identification and analysis of potential threats across different areas of the system [25, 22]. The model also made it possible to evaluate communication flows, trust boundaries, data handling, and attack surfaces throughout development [25, 22].

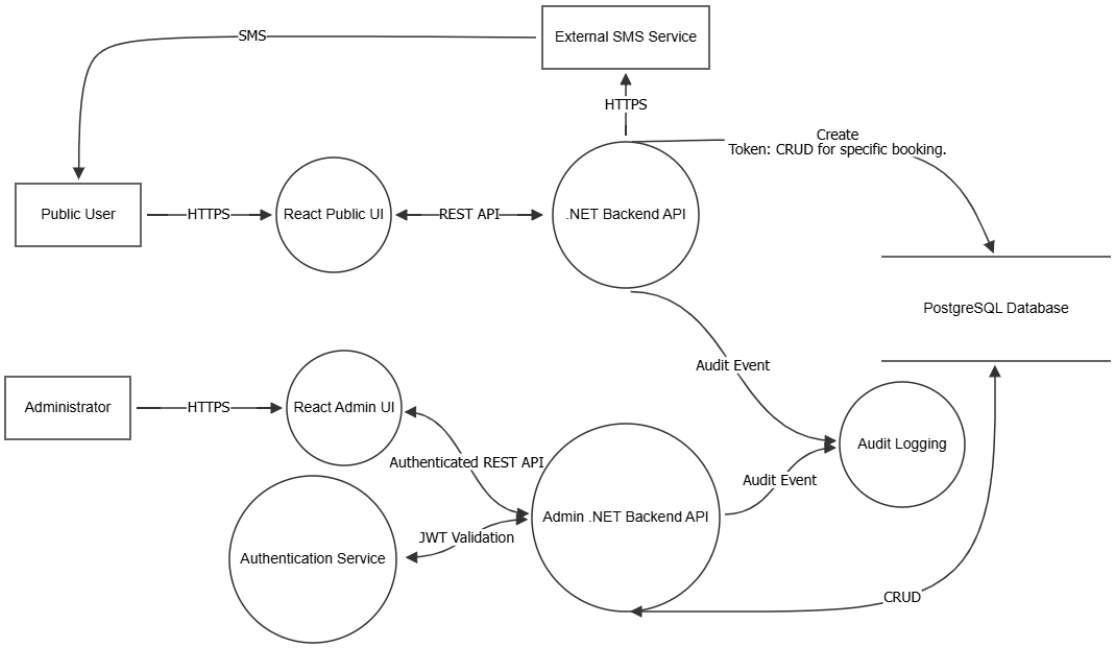


Figure 4: Threat model of the booking system architecture created using OWASP Threat Dragon.

3.4.1 Research Design - Security and Privacy

The security and privacy evaluation followed a qualitative and architecture-oriented approach. By assessing security early in the design process, protective mechanisms could be integrated into the account-free booking system before implementation began [25].

The evaluation emphasized architectural analysis, qualitative threat modeling, and analysis of design trade-offs rather than formal security certification or penetration testing [25, 22]. This approach was well suited to the study because of its focus on architectural structure and security by design. Continuous evaluation of the risks involved in the system's design allowed this modeling technique to visually represent trade-offs by adding or removing artifacts from the model.

The architectural threat model presented in Figure 4 supported the identification and analysis of potential threats across different areas of the system. The model also made it possible to evaluate communication flows, trust boundaries, data handling, and attack surfaces throughout development [25, 22]. As the system architecture was changed, the model was updated and re-evaluated. The visualization of the system made it easier to identify different attack surfaces in the design. When an attack surface was identified, further research was used to expose security risks related to that specific surface. Particular attention was given to how reduced reliance on user accounts influenced authentication requirements, access control, misuse prevention, accountability, and handling of customer information.

3.4.2 Materials and Apparatus - Security and Privacy

The primary material used during the security and privacy evaluation consisted of scientific literature, GDPR-related research, security guidelines, privacy-by-design principles, and the implemented booking system prototype.

Additional implementation-related material included technical documentation and development resources related to .NET web application security, JWT authentication, HTTPS communication, CORS configuration, audit logging, and secure system architecture.

Threat modeling was carried out with OWASP Threat Dragon in order to visualize communication flows, trust boundaries, attack surfaces, and handling of customer information throughout the system architecture [22].

3.4.3 Procedure - Security and Privacy

Different architectural alternatives were evaluated during the design process, including traditional account-based authentication, token-based booking management, and lightweight administrative authorization models.

Threat modeling using OWASP Threat Dragon was integrated iteratively to identify vulnerabilities, trust boundaries, and possible attack scenarios connected to booking functionality, authentication mechanisms, external services, and life-cycle management [22, 25].

Privacy-related design decisions focused on minimizing the collection and retention of personal information, reducing administrative exposure to customer data, and implementing automated life-cycle management of completed bookings [23, 10, 13].

3.4.4 Data Analysis - Security and Privacy

The security and privacy evaluation used qualitative risk analysis focused on identifying vulnerabilities connected to misuse scenarios, privacy-related exposure risks, and operational consequences related to architectural and interaction- related design decisions [25].

Threat Dragon diagrams and identified threat scenarios formed the analytical material used during the evaluation of security and privacy. Identified risks were analyzed in relation to relevant countermeasures and mitigation strategies [4, 7, 14].

The evaluation focused on architectural and operational implications rather than quantitative measurement of security performance. The presented risk levels therefore represent qualitative estimations based on perceived likelihood and potential impact rather than formally validated security metrics.

4 Results

The result of this study is a compilation of research, interviews, user tests, observation, threat modeling, and risk handling with threat analysis. Each section has the result for that specific part of the study.

4.1 User Experience

The user experience evaluation identified recurring interaction patterns and workflow-related issues within both the administrative interface and the public booking flow. The findings primarily concerned workflow efficiency, navigation behavior, interaction expectations, and handling of repetitive administrative tasks.

4.1.1 Initial Interview and Requirement Gathering

The initial interview with administrative staff revealed that existing booking management involved considerable manual handling of bookings and customer information, particularly after completed rentals. Employees described periods with many simultaneous bookings as operationally demanding and emphasized the importance of minimizing unnecessary interaction steps during daily workflow management.

The interview additionally identified a need for:

- simplified administrative workflows,
- fast access to commonly used booking functionality,
- reduced manual handling of completed bookings,
- and information on pick-up and return times.

The collected requirements influenced the early design focus toward minimizing workflow interruptions and reducing repetitive administrative interaction. It also highlighted the importance of minimizing the workload for bookings. The collaborating company primarily operates as a paint and decorating retailer rather than a rental business. As a result, employees emphasized the importance of minimizing the administrative workload associated with booking management.

4.1.2 Early Prototype Evaluation

Evaluation of second prototype identified several usability-related issues connected to workflow structure and handling of booking-related information. The evaluation included both a customer-facing booking interface and an administrative interface used for booking management and equipment handling.

Figure 5 illustrates the customer-facing prototype used during the early stages of development. The prototype was evaluated with a focus on booking creation, navigation, and overall interaction flow. Feedback indicated that users generally understood the booking process, but several

improvements were identified regarding workflow clarity and the reduction of unnecessary interaction steps.

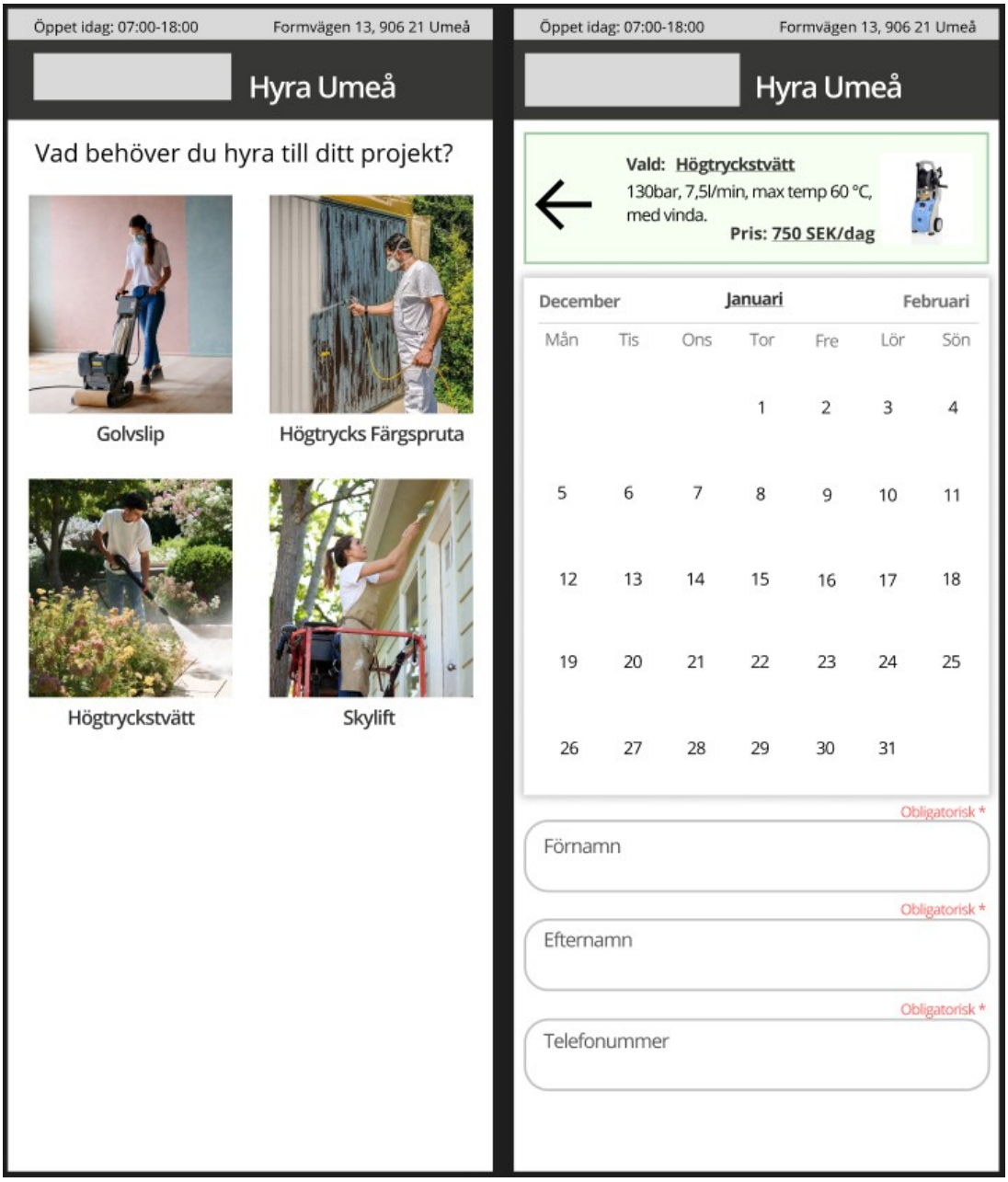


Figure 5: Early customer-facing booking prototype evaluated during the second user experience testing phase.

Figure 6 shows the administrative prototype used during the second employee evaluation. During this evaluation, some interview questions focused on specific features related to the final return process performed either by personnel or automatically by the system. For example, should the employee receiving a returned tool be responsible for performing a final inspection before customer information is removed, or should this life-cycle management be handled entirely by the backend system?

In the prototype where an employee was responsible for the final inspection, older bookings were clearly highlighted with a red outline and displayed at the top of the list, making them difficult to overlook. The intention was to simplify the handling of returned equipment, particularly in cases where items were damaged. If customer data is removed immediately after a return is registered, the company may lose the ability to determine who was responsible for any damage, potentially creating accountability issues.

The employees agreed that handling should be automatic and that user data should be removed by the system after 2 weeks.

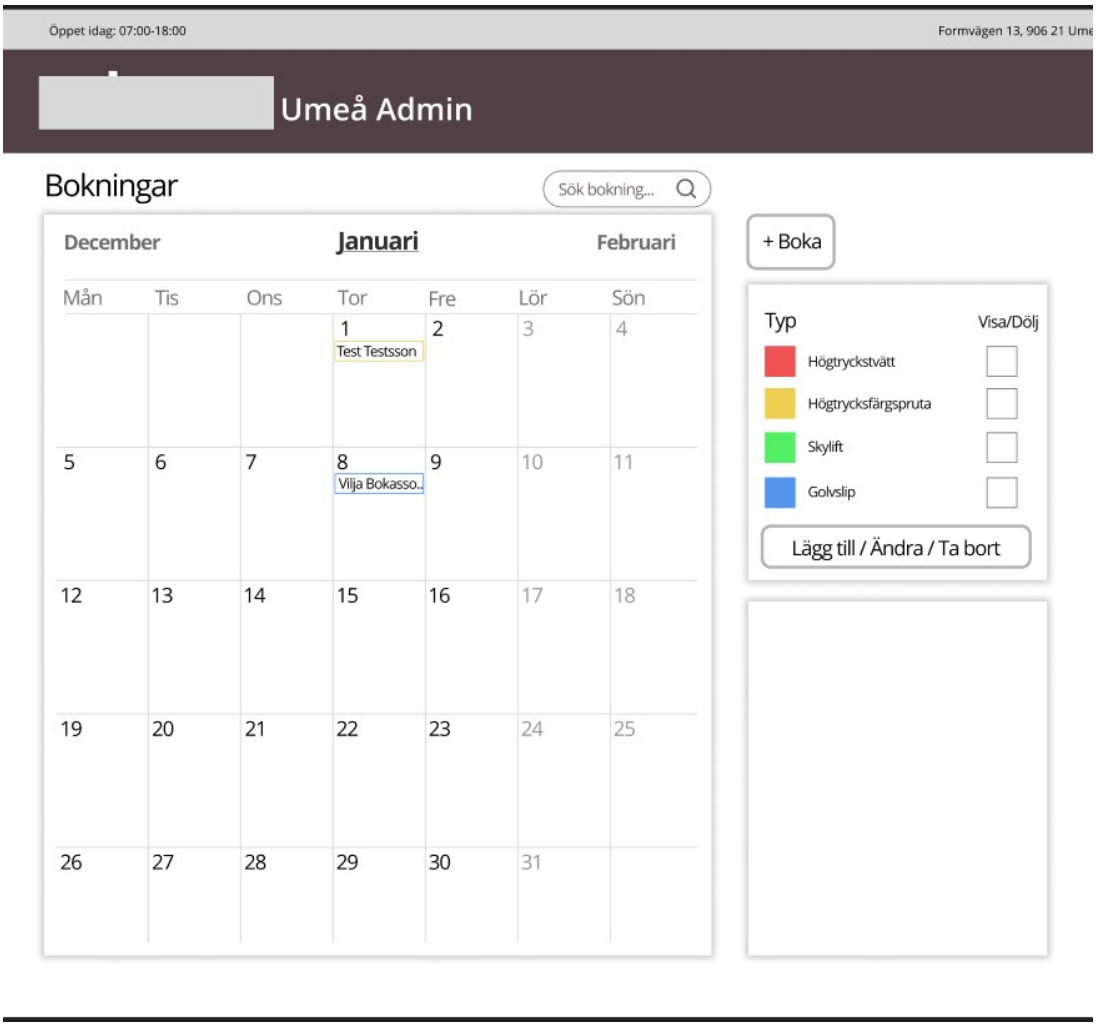


Figure 6: Early administrative prototype evaluated with employees responsible for booking and equipment management.

The third interview focused primarily on administrative workflows, handling of customer information, and account management practices.

Employees expressed a preference for using a shared administrative account instead of maintaining separate employee accounts. Participants described individual account management as unnecessary within the organizational context because most employees required access to similar functionality during daily operations. They also shared the same workstation, which further

increesed the friction if they were to switch account or log in to the system with every use.

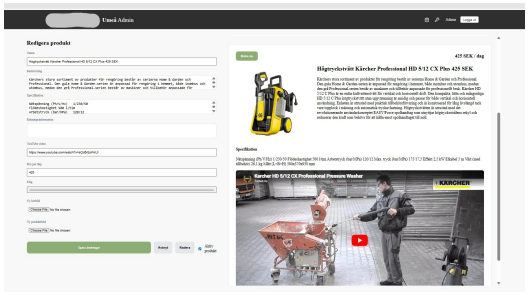
Based on the results from the second and third interviews, the system implementation transitioned toward automated life-cycle management of customer information. Customer-related personal data was automatically removed two weeks after a booking had been completed and marked as returned, while non-identifiable booking information required for operational statistics remained stored within the system. The administrative interface was improved to support faster workflows and more automation.

4.1.3 Final User Testing

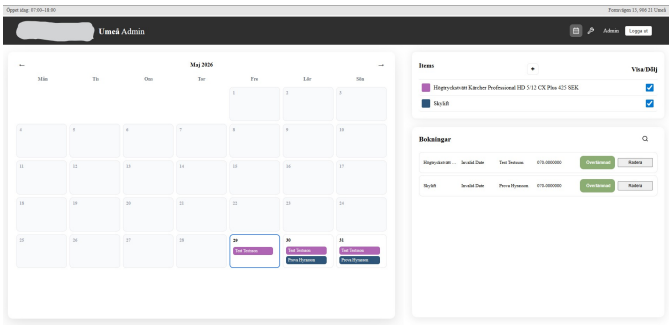
Before the tests were carried out, deployment testing revealed a display-related issue connected to the monitor environment used within the company. Lower vertical screen resolution caused parts of the interface layout to behave differently compared to the development environment. The interface was scaled to fit the lower resolution.

The findings presented in this section are based on observations, scenario-based user testing, and semi-structured interviews. A complete summary of the test scenarios, observation notes, and interview material is provided in **Appendix B**, while the thematic analysis of the collected data is presented in **Appendix C**.

Figure 7 illustrates the final administrative interfaces evaluated during testing. Employees used these interfaces to manage bookings, handle equipment returns, and perform day-to-day operational tasks.



(a) Administrative equipment management



(b) Administrative booking management

Figure 7: Final administrative interfaces were evaluated during user testing. The screenshots illustrate equipment administration, booking management, and operational workflows used by employees.

The final user testing identified several interaction-related issues where user expectations did not fully align with implemented system behavior.

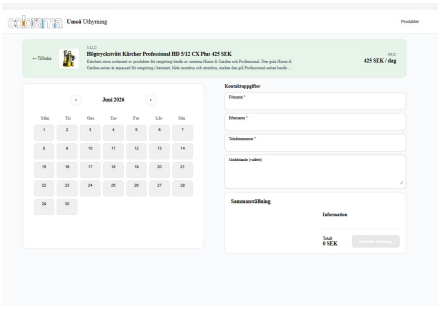
The administrative interfaces were generally perceived as understandable and operationally efficient. Employees highlighted that common management tasks could be completed with relatively few interaction steps compared to earlier workflow approaches. However, an individual difference was noticed in the observed user scenarios; the workflows were different depending on the em-

ployee. This difference had to be taken into account. Features were expected to exist in different parts of the system, and one solution for this problem was to include the same functionality in many separate locations. This would support a more individualized workflow.

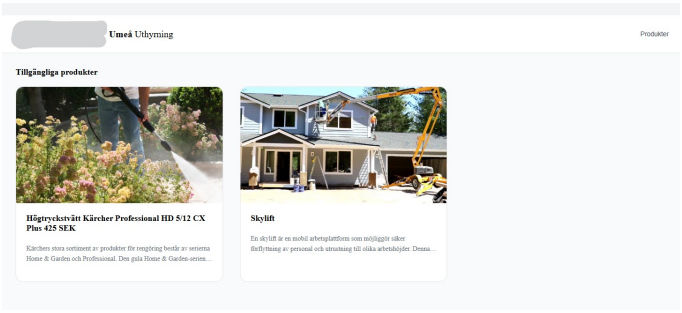
Observations that were made during the scenario-based testing were: Within the search functionality, users expected the search field to automatically receive keyboard focus when the search interface was opened. In popup-based interface elements, attempts to mark or copy text occasionally triggered unintended close behavior, resulting in workflow interruptions during administrative interaction.

Observations also showed continued variation in administrative workflow patterns. Some employees expected frequently used functionality to remain accessible from multiple interface locations, depending on the navigation context and current task flow. One recurring example involved functionality for marking equipment as handed over, where participants requested access through additional workflow views beyond the originally implemented interaction path.

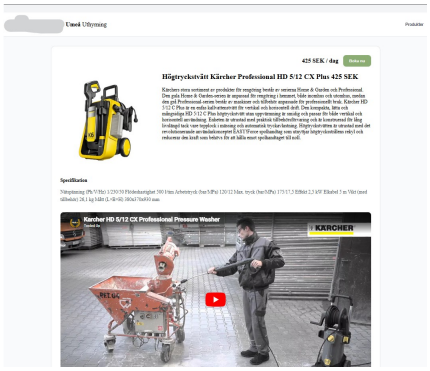
Figure 8 illustrates the final customer-facing interfaces evaluated during testing.



(a) Public booking interface



(b) Public equipment overview page



(c) Equipment details page

Figure 8: Design of the public interface in the final user tests.

The customer-facing interfaces were generally perceived as intuitive and easy to navigate. Users were able to browse equipment, access detailed information, and create reservations without requiring user accounts. Several participants nevertheless requested additional navigation support, particularly the ability to move backwards between booking stages without restarting the booking process.

Users also requested support for period bookings covering multiple consecutive days instead of requiring repeated individual reservations. Feedback indicated that the original booking model created unnecessary complexity when reserving equipment for longer periods. The complete thematic analysis, including the identified themes and supporting observations from the user evaluation, is presented in **Appendix B**.

This feedback motivated a redesign of the booking model. As illustrated in Figure 9, the booking system transitioned from associating identities with individual booking dates to associating a single booking identity with an entire booking period.

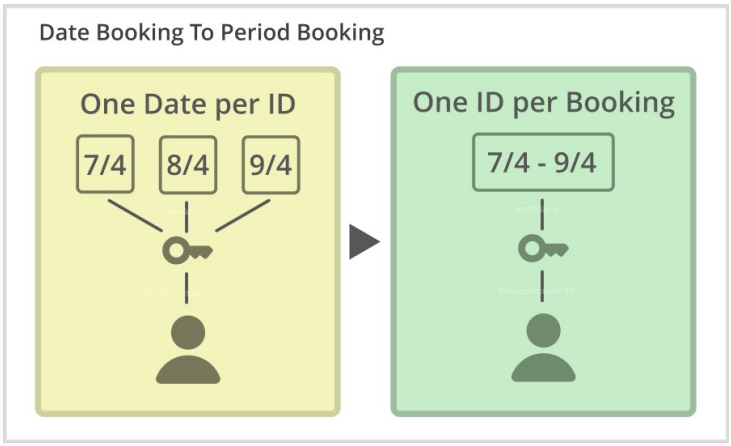


Figure 9: Illustration of the transition from date-based booking identities to period-based booking identities. The key symbol represents the booking token associated with the reservation.

The redesigned booking structure simplified reservation management for both customers and administrators by reducing the number of required booking operations while maintaining the account-free booking approach.

Overall, qualitative feedback collected during final testing indicated that both customer-facing and administrative interfaces supported the intended workflows effectively. The remaining usability issues primarily concerned navigation preferences, workflow flexibility, and interaction convenience rather than fundamental problems with system functionality. Several identified issues were subsequently addressed through iterative refinement before deployment, including improvements to booking workflows, life-cycle management, and support for period-based reservations.

4.2 Security and Privacy

The security and privacy evaluation identified several risks connected to public booking functionality, authentication strategies, handling of customer information, external communication services, and administrative workflows.

The threat modeling process identified the following risks:

- **Shared user accounts.** The use of shared accounts increases the risk of unauthorized access to and modification of customer booking data due to the wider distribution of credentials. Furthermore, shared accounts reduce accountability, as it becomes difficult to determine which individual performed a specific action when changes are logged under the same account.
- **Public booking API.** The public booking API does not implement authentication mechanisms, making it vulnerable to misuse. Potential threats include the creation of fraudulent bookings that could reduce service availability for legitimate customers, as well as an increased exposure to denial-of-service and distributed denial-of-service attacks.
- **SQL Server.** No backup solution has been implemented for the database. Consequently, if the database were to become corrupted, manipulated, or deleted, both historical booking statistics and active booking records could be permanently lost and may be impossible to reconstruct.
- **Public SMS service.** Since the SMS service handles access tokens and processes personal information, the choice of service provider is security-critical. Important considerations include the provider's security guarantees, data retention policies, and compliance with privacy requirements. The provider's practices should align with the security and privacy commitments made by the booking application to its users.

The risks presented above represent the most relevant findings from the threat modeling and risk assessment activities. The complete risk assessment results, including detailed risk classifications and mitigation considerations, are available in **Appendix A**.

4.2.1 Public Booking Functionality

The public booking functionality represented one of the most exposed components within the system architecture, as booking operations were intentionally designed to be accessible without requiring customer authentication. While this design choice improved usability and reduced barriers to booking, it also introduced several security challenges. During discussions with the collaborating company, the decision was made to initially prioritize accessibility and low interaction friction. Additional authentication mechanisms were considered as a potential future mitigation if misuse becomes a practical concern.

The threat modeling process identified the following risks:

- **Automated fake bookings.** Because bookings can be created without authentication, an attacker could automate booking requests and generate a large number of fraudulent reservations. This could reduce the availability of resources for legitimate customers and negatively impact trust in the system. A possible mitigation would be to implement rate limiting, CAPTCHA verification, and validation mechanisms to distinguish legitimate users from automated bots.

- **Malicious API usage.** Publicly accessible API endpoints may be abused through excessive requests, malformed input, or attempts to exploit application vulnerabilities. Such attacks could affect system availability or expose weaknesses in the implementation. A possible mitigation would be to introduce request throttling, input validation, monitoring, and web application firewall protections.
- **Unauthorized booking access through exposed booking links.** If booking links are accidentally shared or intercepted, unauthorized individuals may gain access to booking details or perform actions on behalf of legitimate customers. A possible mitigation would be to use sufficiently long, cryptographically secure tokens and limit the information exposed through public links.
- **Leaked or predictable booking tokens.** If booking tokens are generated using predictable patterns or are exposed through logs, URLs, or third-party services, attackers may be able to guess or obtain valid tokens and gain unauthorized access to bookings. A possible mitigation would use existing frameworks to generate tokens using a cryptographically secure random number generator and ensure that tokens are stored and transmitted securely.

These risks were primarily linked to the system's goal of minimizing interaction friction and avoiding the need for user account management. Therefore, appropriate technical safeguards are necessary to balance usability with security while preserving the accessibility benefits of the public booking process.

4.2.2 External Communication Services

The external SMS provider represented an important risk area within the system architecture, as the system relied on SMS communication for reminders, booking management links, and, if needed, booking confirmations. As a result, risks affecting the communication service could directly impact both system reliability and the secure handling of customer-related information.

The threat modeling process identified the following risks:

- **Impersonation of the booking service.** Attackers may attempt to impersonate the booking service by sending fraudulent messages that appear to originate from the organization. Such messages could be used to mislead customers, collect sensitive information, or redirect users to malicious websites. A possible mitigation would be to use a trusted SMS-provider, clearly identify the sender, and educate customers about legitimate communication channels.
- **Exposure of booking-related information during communication.** SMS messages may contain booking details or management links that could be accessed by unauthorized individuals if messages are intercepted, viewed on unlocked devices, or delivered to incorrect recipients. A possible mitigation would be to minimize the amount of sensitive information included in messages and ensure that booking links use secure, high-entropy tokens that do not expose customer information directly.

- **Third-party service downtime.** Because SMS delivery depends on an external provider, outages or service disruptions could prevent customers from receiving confirmations, reminders, or booking management links. This could negatively affect both user experience and operational processes. A possible mitigation would be to select a reliable provider with documented service-level agreements, monitor service availability, and establish fallback communication procedures when possible.

These risks originated from the system's dependence on an external communication provider. Consequently, the security posture and operational reliability of the SMS service became important factors in the overall security and availability of the booking system.

4.2.3 Administrative Access and Traceability

The evaluation additionally identified risks connected to administrative access and accountability.

The preference for shared administrative accounts simplified operational workflows but reduced traceability within the audit logging system. Administrative actions could still be logged, but the system could not always distinguish which employee performed a specific operation.

4.2.4 Personal Data Handling and Life-Cycle Management

The analysis showed that minimizing persistent storage of customer information reduced the amount of sensitive personal data retained within the system while still preserving operational booking functionality.

The inclusion of database storage, public booking flows, and external communication services within the threat model improved visibility regarding exposure points involving personal information.

An earlier implementation approach relied on manual deletion of customer information after completed bookings. Prototype evaluations showed that this introduced repetitive administrative interaction and increased the risk of inconsistent life-cycle handling. As a result, the system transitioned toward automated life-cycle management, where customer information was automatically removed after a predefined retention period once equipment had been returned.

4.2.5 Architectural Separation

The analysis further showed that separating public booking functionality from administrative functionality reduced direct exposure of privileged operations and limited access to sensitive administrative features through public-facing interfaces. This separation became more important as the system's complexity grew when automation was added. The administrative controllers required JWT authentication for access, while the public booking controllers did not.

This separation simplified the communication flows and reduced risks connected to accidental exposure of administrative functionality during development and later during maintenance.

4.2.6 Observed Trade-offs

Several findings identified during the evaluation affected usability, privacy, and security simultaneously.

Reducing authentication requirements simplified booking workflows and minimized interaction friction, while increasing exposure to misuse and reducing reliance on traditional accountability mechanisms.

Similarly, the introduction of automated life-cycle management reduced repetitive administrative interaction while increasing dependence on backend-controlled processes for handling customer information. The increased backend complexity also introduced additional areas requiring security consideration and risk assessment.

Several design changes additionally required compensating controls elsewhere in the system architecture. For example, when traditional security mechanisms were reduced or removed, alternative safeguards were introduced in other parts of the system to maintain operational control and protection of customer information.

These observations were identified throughout the iterative development process and were considered during subsequent design decisions and threat analyses.

Table 3 summarizes the identified threat areas, associated CIA categories, estimated qualitative risk levels, and the number of identified threat scenarios connected to each system component.

4.2.6.1 Risk Analysis

System Area	CIA	Highest Risk	Amount
Authentication Service	C	High	2
PostgreSQL Database	C / I / A	High	3
Audit Logging	I / C	Medium-High	2
External SMS Service	C / A	Medium-High	3
Booking Tokens	C	Medium	2
Customer Personal Data	C	Medium-High	2
Public Booking Flow	A	High	1
Admin Booking Flow	I	Medium	1
HTTPS Communication	C	Medium-High	1
API Keys	C	Medium-High	1
Session / JWT Tokens	C	Medium-High	1
Browser Client	I	Medium-High	1
Booking Availability Data	I	Medium	1
System Infrastructure	A	Medium-High	1

Table 3: Summary of identified risks grouped by system area. The presented risk levels represent qualitative estimations based on perceived likelihood and potential impact. The final column represents the number of identified threat scenarios associated with each system area.

The complete qualitative risk assessment, including individual risk scenarios, likelihood assessments, consequence evaluations, and mitigation considerations, is presented in **Appendix A**.

5 Discussion

This study investigated how a booking system can minimize reliance on user data by removing user accounts and long-term storage. The objective was to maintain usability, operational functionality, and administrative control. The findings from this study show that reducing dependence on user identity changes how responsibility for security, accountability, and system control is distributed throughout the architecture.

Rather than relying on traditional account-based interaction, the implemented system used architectural separation, backend validation, booking tokens, automated life-cycle management, and administrative oversight to support booking operations. The results indicate that these mechanisms made it possible to maintain operational functionality while reducing the amount of personal information retained within the system.

At the same time, the findings show that removing the user accounts does not eliminate security and privacy challenges. Responsibilities handled by user accounts are redistributed to alternative architectural and organizational mechanisms. This illustrates how usability, privacy, and security function as interconnected system properties rather than independent design goals.

5.1 Privacy-Oriented System Design

The study demonstrates one possible architectural approach for replacing user accounts with temporary token-based identity management. By limiting collected information to operationally necessary booking data and automatically removing customer information after completed rentals, the system aligned with GDPR-related principles such as data minimization and storage limitation [23, 16].

The findings also show that privacy as a mechanism is closely connected to the architectural design. This argues that privacy should be included early in the design process [10]. By separating operational data from identifiable customer information, it becomes easier to analyze the dependencies between them and further supports automatic life-cycle management.

This supports privacy-by-design perspectives where privacy protection is integrated directly into system architecture [10, 5]. It's easier to reduce reliance on identity data if we include it in the design. If we treat it as a separate layer, the problem might already be built into the system.

However, the findings also show that reducing stored identity data changes how accountability and operational traceability are maintained. Without user accounts, the system became increasingly dependent on temporary booking tokens, backend validation, and administrative monitoring to maintain operational reliability [4, 7]

5.2 Usability and Reduced Interaction Friction

The evaluation showed that reducing interaction complexity was generally perceived positively by both administrative and public users. Simplified booking flows, reduced account-related inter-

action, and automation of repetitive administrative tasks contributed to more efficient workflows and lower operational friction [11].

As explained in the result, the reduction of friction redistributed some security risk to other parts of the system. In some instances, the risk was moved from the system architecture directly to the collaborating company. The associated risks were known during development, and mitigation strategies were identified, but implementation of these safeguards was deferred unless the risks became operationally significant. This included the shared administrative account and the booking API that lacked authentication.

The findings additionally highlight that usability within administrative systems is strongly influenced by organizational workflow patterns rather than interface structure alone [11]. Employees use different strategies for navigation depending on background, work responsibilities, and task context. This resulted in requests for multiple access paths to similar functionality. The workplace examined in this study consists of a few employees with a high level of trust not only for each other, but also for the customers.

The preference for shared administrative accounts further illustrates how usability and operational convenience may conflict with stricter security principles [2]. From a security perspective, individual accounts provide stronger accountability and traceability. However, employees perceived separate account management as unnecessary complexity within the organizational environment.

This demonstrates that usability-related decisions are not limited to interface design, but also include how authentication, workflow management, and operational routines are integrated into everyday system use [11, 2].

5.3 Security, Accountability, and Architectural Control

The security evaluation showed that minimizing authentication requirements introduced elevated risks connected to publicly accessible booking functionality, exposed booking tokens, external communication services, and reduced traceability.

The findings demonstrate that systems prioritizing low-friction interaction require compensating safeguards to maintain acceptable levels of operational control and protection of personal information [2, 25]. This also depends highly on the context and purpose of the system. If we, for example, were to include payment in the booking page, this could act as a form of safeguard or authentication, but would at the same time increase the responsibilities by handling credit card information.

Threat modeling using OWASP Threat Dragon proved useful for identifying trust boundaries, sensitive communication flows, and architectural areas where confidentiality, integrity, and availability risks were concentrated [22, 25]. The visual modeling process helped connect identified threats to specific architectural decisions and supported analysis of how privacy, usability, and security influenced each other throughout development.

5.4 Trade-offs Between Usability, Privacy, and Security

A central finding throughout the study is that improvements in one system aspect frequently introduced challenges or dependencies in another. Rather than functioning as isolated qualities, usability, privacy, and security continuously influenced each other throughout the design and implementation process [2, 5]. An example of these dependencies can be seen in Figure 10.

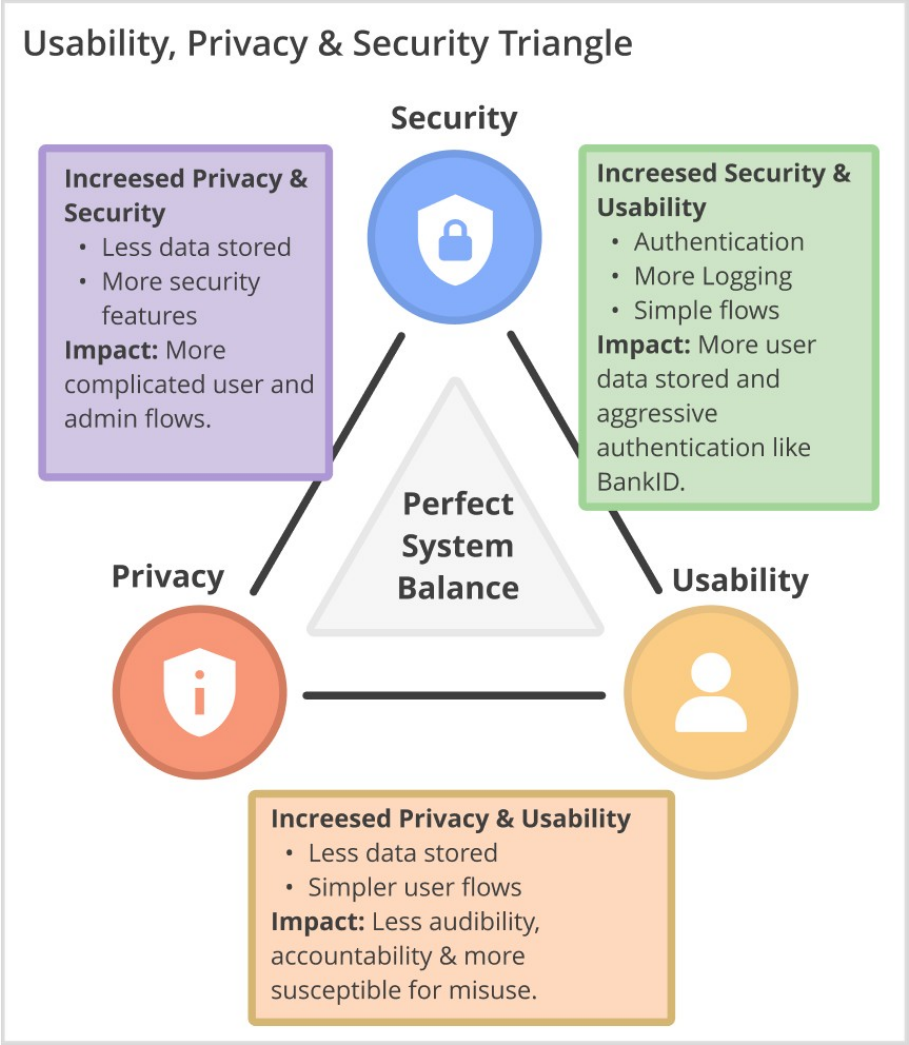


Figure 10: Conceptual model illustrating trade-offs between usability, privacy, and security in account-free booking systems. Improvements in one area may introduce challenges or dependencies in another.

The dependencies are highly dependent on context, and it was discovered that changing one part often made changes in other parts of the system. It can be argued that the removal of user accounts strengthened the part of security aligned with the exposure of user data, but at the same time, weakened the security aligned with accountability [4, 7].

The shift in responsibilities between the different parts of the system also highlights how the solution affects the trade-offs between security, privacy and user experience. This shows how important it is to analyze shifts in the architecture carefully to not introduce new risks to the

system's architecture.

Automation of life-cycle management has reduced the extent of risks related to customer information, and at the same time aligns very well with GDPR regulations on data minimization [23, 16]. This is another example from the study where the solution shows a big positive impact on security, privacy, and user experience.

Architectural separation emerged as one of the most important balancing mechanisms within the system [24, 14]. Separating public booking functionality from administrative functionality reduced exposure of privileged operations, improved control over how customer information was processed, and clarified trust boundaries throughout the architecture. This allowed the system to maintain relatively low-friction public interaction while still preserving administrative control and backend-centered security mechanisms.

These findings demonstrate that usability, privacy, and security cannot be independently optimized in systems designed to reduce reliance on persistent identity.

Rather than eliminating trade-offs, the implemented system redistributed them across different parts of the architecture and operational workflow. The study therefore suggests that account-free systems do not remove security or privacy challenges, but instead shift responsibility away from persistent user identity toward architectural control mechanisms, automation, and organizational oversight.

5.5 Methodological Reflection

The methodological approach, where the iterations in User Centered Design, paired well with the risk modeling and threat analysis [11, 25]. The combination made it easier to find what caused the trade-offs, but it also served as a good measure to compare different architectural solutions. User Centered Design focuses on the interaction flows [11], and the OWASP Threat Dragon model could have been used to analyze user flows from a user experience perspective.

Threat modeling using OWASP Threat Dragon proved useful for visualizing trust boundaries, communication flows, and potential attack surfaces throughout the system architecture [22]. To research how to make a system secure proves itself hard, partly because technology changes, but also because of its wide range [25]. When looking for vulnerabilities in specific parts like API, HTTP, or SQL with Entity Framework, it becomes easier to find relevant threats to specific scenarios [24, 8].

The methodological approach also introduced limitations. The security evaluation relied primarily on qualitative threat analysis and architectural assessment rather than penetration testing or formal security auditing [25]. This removes the possibility of using this study as a guide to similar projects. Similarly, the user evaluations were conducted within a specific organizational context, which may limit the general use of this specific implementation [11].

The qualitative evaluation methods provided detailed feedback regarding user behavior, but it was clear that the method chosen could not be used to fully optimize the user experience

[11]. The limited number of test subjects also makes it hard to generalize the feedback to a generalizable opinion [11].

Despite these limitations, the combination of iterative development, qualitative evaluation, and architectural threat modeling provided a suitable foundation for exploring how account-free booking systems can balance usability, privacy, and security [12].

5.6 Limitations

Several limitations affected the scope and interpretation of the study.

The usability evaluation was conducted using relatively small participant groups and qualitative evaluation methods rather than large-scale quantitative usability analysis. The findings, therefore, represent exploratory design-oriented observations rather than statistically generalizable usability measurements [11].

The system was additionally evaluated within a controlled project environment and was not deployed as a long-term production system. Because of this, the study could not evaluate long-term operational behavior, scalability under sustained real-world usage, or evolving patterns of misuse over time.

The security evaluation focused primarily on qualitative threat analysis and architectural assessment rather than formal penetration testing or quantitative security measurement [25]. The identified risk levels should therefore be interpreted as qualitative estimations based on perceived likelihood and operational impact [25].

Finally, several workflow-related findings were influenced by the operational environment of the collaborating company. Some observations regarding usability, administrative workflows, and account management preferences may therefore be organization-specific and not directly transferable to all booking system contexts [11].

5.7 Future Work

Future research could investigate:

- long-term deployment of account-free booking systems in production environments,
- quantitative usability evaluation involving larger participant groups,
- hybrid authentication approaches combining low-friction interaction with lightweight verification,
- automated abuse detection and rate-limiting mechanisms,
- and comparative studies between account-free and traditional account-based booking systems.

Future work could additionally explore how alternative communication and verification methods influence the balance between usability, accountability, and privacy within systems designed to minimize persistent identity.

6 Conclusion

This thesis investigated how a booking system for tool rental could reduce collection and retention of personal data without relying on user accounts.

The developed system replaced traditional account-based booking with an account-free approach where customers managed reservations through SMS-delivered booking tokens. Customer information was automatically removed after completed bookings, reducing long-term storage of personal data and eliminating the need for manual life-cycle management.

User evaluations showed that the account-free booking workflow was generally perceived as simple and understandable. Users requested support for bookings spanning multiple consecutive days, resulting in a redesign from date-based booking identities to period-based bookings. Administrative users additionally preferred multiple navigation paths to frequently used functions and highlighted the importance of minimizing interaction steps during booking management.

The security and privacy evaluation showed that removing user accounts reduced the amount of stored personal information but introduced new challenges related to accountability and misuse prevention. Threat modeling identified the PostgreSQL database, public booking functionality, booking tokens, and external SMS communication as the most exposed areas of the system architecture. These risks were addressed through backend validation, audit logging, HTTPS communication, architectural separation, and controlled handling of customer information.

One of the most significant findings of the study was that usability, privacy, and security continuously influenced each other throughout development. Measures intended to improve privacy and reduce interaction friction often weakened traditional traceability mechanisms, while security controls could increase workflow complexity. Rather than eliminating trade-offs, the implemented solution redistributed responsibility from persistent customer identity toward architectural safeguards and organizational routines.

The findings indicate that account-free booking systems can effectively facilitate temporary and task-oriented rental environments. However, it's important to note that the evaluation was carried out on a prototype in a controlled setting. Therefore, the results should be viewed as design-oriented insights rather than proof of long-term operational performance. Successful implementation relies on carefully addressing issues of accountability, traceability, and preventing misuse when user accounts are eliminated from the booking process.

References

[1] Informationssäkerhet och cybersäkerhet — mcf.se. `https://www.mcf.se/sv/amnesomraden/informationssakerhet-och-cybersakerhet/`. [Accessed 30-06-2026].

[2] Anne Adams and Martina Angela Sasse. Users are not the enemy. *Communications of the ACM*, 42(12):40–46, 1999.

[3] Joseph Bonneau, Cormac Herley, Paul C Van Oorschot, and Frank Stajano. The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. In *2012 IEEE symposium on security and privacy*, pages 553–567. IEEE, 2012.

[4] Denis Butin, Marcos Chicote, and Daniel Le Métayer. Log design for accountability. In *2013 IEEE Security and Privacy Workshops*, pages 1–7. IEEE, 2013.

[5] Ann Cavoukian. Privacy by design in law, policy and practice. *A white paper for regulators, decision-makers and policy-makers*, 2011.

[6] John W Creswell. *Qualitative, quantitative and mixed methods approaches*. Sage, 2014.

[7] Michael Dalton, Christos Kozyrakis, and Nickolai Zeldovich. Nemesis: Preventing authentication & [and] access control vulnerabilities in web applications. 2009.

[8] Ian Fette and Alexey Melnikov. The websocket protocol. Technical report, 2011.

[9] Paul A Grassi, Michael E Garcia, and James L Fenton. Digital identity guidelines (). *NIST special publication*, 800:63–3, 2017.

[10] Paolo Guarda and Nicola Zannone. Towards the development of privacy-aware systems. *Information and Software Technology*, 51(2):337–350, 2009.

[11] Rex Hartson and Pardha S Pyla. *The UX Book: Process and guidelines for ensuring a quality user experience*. Elsevier, 2012.

[12] Alan R. Hevner, Salvatore T. March, Jinsoo Park, and Sudha Ram. Design science in information systems research. *MIS Quarterly*, 28(1):75–105, 2004.

[13] Sarah Higgins and G Pryor. The lifecycle of data management. *Managing research data*, pages 17–46, 2012.

[14] Andrew Hoffman. *Web application security*. " O'Reilly Media, Inc.", 2024.

[15] IBM. What is a rest api (restful api)? `https://www.ibm.com/think/topics/rest-apis`, 2025. Accessed: 2026-05-16.

[16] Lina Jasmontaitė-Zaniewicz, Alessandra Calvi, Renáta Nagy, and David Barnard-Wills. The gdpr made simple (r) for smes. In *The GDPR made simple (r) for SMEs*. Brussels: VUBPRESS, 2021.

[17] Weizhao Jin, Xiaoyu Ji, Ruiwen He, Zhou Zhuang, Wenyuan Xu, and Yuan Tian. Sms goes nuclear: Fortifying sms-based mfa in online account ecosystem. In *2021 51st Annual IEEE/IFIP International Conference on Dependable Systems and Networks Workshops (DSN-W)*, pages 7–14. IEEE, 2021.

[18] Microsoft. Entity framework core documentation, 2025. Accessed 2026-06-17.

[19] Chris Moschovitis. *Cybersecurity program development for business: the essential planning guide*. John Wiley & Sons, 2018.

[20] Jakob Nielsen. *Usability Engineering*. Morgan Kaufmann, 1994.

[21] OWASP Foundation. Application security verification standard 4.0, 2023. Accessed: 2026-05-21.

[22] OWASP Foundation. Owasp threat dragon. urlhttps://owasp.org/www-project-threat-dragon/, 2025.

[23] Protection Regulation. Regulation (eu) 2016/679 of the european parliament and of the council. *Regulation (eu)*, 679(2016):10–3, 2016.

[24] Leon Shklar and Richard Rosen. *Web application architecture*, volume 36. John Wiley & Sons, 2009.

[25] Adam Shostack. *Threat Modeling: Designing for Security*. Wiley, 2014.

[26] Atta Ullah, Muhammad Usman, Muhammad F Abrar, Najeeb Ullah, Ibrar A Shah, and Muhammad F Nadeem. Systematic performance, and security evaluation of. net models for accessing database. *VFAST Transactions on Software Engineering*, 9(4):18–24, 2021.

A Appendix: Complete Risk Assessment Results

	Tillgång	Egenskap (CIA/STRIDE)	Riskscenario	Orsaksbeskrivning	Konsekvensbeskrivning	Värde S 1-4	Sannolikhetsnivå	Värde K 1-4	Konsekvensnivå	Risknivå
R1	React Public UI	Availability / DoS	Public interface overload	Automated requests or spam traffic	System becomes slow or unavailable	2	Medelhög	3	Betydande	4
R2	React Public UI	Integrity / Tampering	Manipulated client-side data	Requests modified in browser	Invalid bookings sent to backend	4	Mycket hög	2	Måttlig	5
R3	React Admin UI	Spoofing	Unauthorized administrative access	Stolen authentication tokens	Unauthorized booking management	4	Mycket hög	4	Allvarlig	7
R4	React Admin UI	Information Disclosure	Exposure of administrative information	Incorrect frontend routing or caching	Sensitive data shown to unauthorized users	2	Medelhög	4	Allvarlig	5
R5	.NET Backend API	Tampering	SQL injection	Unsanitized user input	Database corruption or data leakage	1	Låg	4	Allvarlig	4
R6	.NET Backend API	Availability / DoS	API overload	Large number of simultaneous requests	API becomes unavailable	3	Hög	3	Betydande	5
R7	.NET Backend API	Elevation of Privilege	Unauthorized admin endpoint access	Incorrect authorization handling	Attacker gains administrative privileges	3	Hög	4	Allvarlig	6
R8	.NET Backend API	Information Disclosure	Exposure of personal data through API	Incorrect API responses or logging	GDPR-related data leakage	2	Medelhög	4	Allvarlig	5
R9	Authentication Service	Spoofing	JWT forgery	Weak signing keys	Unauthorized authentication	1	Låg	3	Betydande	3
R10	Authentication Service	Repudiation	Lack of traceability	Missing authentication logs	Difficult incident investigation	2	Medelhög	3	Betydande	4
R11	PostgreSQL Database	Information Disclosure	Database leak	Compromised server or backup	Exposure of customer data	2	Medelhög	4	Allvarlig	5
R12	PostgreSQL Database	Tampering	Unauthorized database modification	Unauthorized database access	Incorrect bookings or data loss	2	Medelhög	3	Betydande	4
R13	PostgreSQL Database	Availability	Database outage	Server failure or resource exhaustion	Booking system becomes unavailable	3	Hög	3	Betydande	5
R14	Audit Logging	Repudiation	Manipulated audit logs	Unauthorized access to logs	Events cannot be verified	2	Medelhög	4	Allvarlig	5
R15	Audit Logging	Information Disclosure	Sensitive data inside logs	Excessive logging of personal data	GDPR/privacy risks	2	Medelhög	3	Betydande	4
R16	External SMS Service	Information Disclosure	SMS interception	External or insecure communication	Booking information exposed	3	Hög	3	Betydande	5
R17	External SMS Service	Availability	SMS provider outage	Third-party service downtime	Confirmation messages not delivered	1	Låg	3	Betydande	3
R18	External SMS Service	Spoofing	Fake SMS messages	SMS spoofing or phishing	Users deceived by fake bookings	2	Medelhög	3	Betydande	4
R19	Booking Tokens	Spoofing	Token guessing	Weak or predictable tokens	Unauthorized booking access	1	Låg	3	Betydande	3
R20	Booking Tokens	Information Disclosure	Exposed booking links	Shared SMS or browser history	Unauthorized booking management	3	Hög	3	Betydande	5
R21	Customer Personal Data	Confidentiality	Unauthorized access to customer data	Weak access control	Privacy violations	2	Medelhög	4	Allvarlig	5
R22	Customer Personal Data	Storage Limitation	Excessive personal data retention	Missing deletion or anonymization	GDPR violations	2	Medelhög	3	Betydande	4
R23	Public Booking Flow	Availability / DoS	Automated fake bookings	Bots or scripts	Available booking times blocked	4	Mycket hög	4	Allvarlig	7
R24	Admin Booking Flow	Integrity	Incorrect administrative handling	Human error	Incorrect bookings or modifications	3	Hög	3	Betydande	5
R25	HTTPS Communication	Information Disclosure	Man-in-the-middle attack	Missing TLS encryption	Intercepted communication	1	Låg	4	Allvarlig	4
R26	API Keys	Information Disclosure	Exposed API keys	Hardcoded or leaked secrets	Abuse of external services	2	Medelhög	3	Betydande	4
R27	Session/JWT Tokens	Spoofing	Stolen authentication tokens	Insecure cookies	Session hijacking	2	Medelhög	3	Betydande	4
R28	Browser Client	Tampering	Malicious JavaScript injection	Unsanitized input	Stolen sessions or manipulated UI	2	Medelhög	3	Betydande	4
R29	Booking Availability Data	Integrity	Race condition during booking	Concurrent booking requests	Double bookings	2	Medelhög	3	Betydande	4
R30	System Infrastructure	Availability	Server outage	Infrastructure failure or attack	Entire system unavailable	3	Hög	3	Betydande	5

A.1: Complete risk assessment of the final iteration.

B Appendix: Användarutvärdering

Den slutliga användarutvärderingen genomfördes med totalt sju deltagare. Tre deltagare testade det administrativa gränssnittet och fyra deltagare testade det publika bokningsgränssnittet. Utvärderingen bestod av scenariobaserade användartester, observationer samt semistrukturerade intervjuer efter genomförda uppgifter.

Genomförda scenarier

Administrativa användare

De administrativa användarna ombads genomföra följande uppgifter:

1. Registrera en ny bokning för Sven Svensson den 18/5 av en högtryckstvätt.
2. Leta upp bokningen som gjorts av Test Testsson och ändra telefonnumret till 070-0000000.
3. Sven Svensson har insett att han inte kommer att hinna tvätta sin uppfart den 18/5. Avboka därför bokningen.
4. Testa Bokasson kommer in till butiken med en mattvätt som han har använt färdigt. Registrera att produkten har återlämnats.
5. Kontrollera när högtryckstvätten är tillgänglig under perioden 25/5–31/5 eftersom Sven Svensson vill veta om någon av dessa dagar passar honom bättre.
6. Mattvätten som återlämnades visade sig ha ett trasigt munstycke. Markera utrustningen som inaktiv så att den inte kan bokas av kunder.
7. Det visar sig att det finns ett extra munstycke i lager till den trasiga mattvätten. Markera därför utrustningen som aktiv igen.

Kunder

Kunderna ombads genomföra följande uppgifter:

1. Hitta en produkt som kunde hyras.
2. Genomföra en bokning för ett angivet datum.
3. Avboka en befintlig bokning.

Intervjufrågor

Efter genomförda scenarier genomfördes semistrukturerade intervjuer med deltagarna. Följande frågor användes som stöd under intervjuerna:

1. Hur upplevde du bokningsprocessen?

2. Var det någon funktion som var svår att hitta?
3. Upplevde du att systemet var enkelt att förstå?
4. Var det någon uppgift som kändes onödigt komplicerad?
5. Saknade du någon funktion eller information?
6. Hur upplevde du navigeringen i systemet?
7. Finns det något du skulle vilja förbättra?
8. Hur skulle du beskriva systemet som helhet?

Observationer

Under användartesterna observerades deltagarnas interaktion med systemet. Fokus låg på hur väl användarna kunde genomföra uppgifterna, eventuella problem som uppstod samt behov av stöd från testledaren.

Administrativa användare

Positiva observationer

- Samtliga deltagare kunde registrera nya bokningar utan stöd från testledaren.
- Navigeringen mellan produkter och bokningar upplevdes som logisk.
- Sökfunktionerna användes intuitivt för att hitta och hantera bokningar.
- Hantering av återlämnade produkter kunde genomföras utan större svårigheter.

Identifierade problem

- Vissa deltagare behövde extra tid för att hitta funktioner för redigering och avbokning.
- Några användare var osäkra på om deras ändringar hade sparats korrekt.
- Tydligare återkoppling efter genomförda åtgärder efterfrågades.
- Vissa backend-begränsningar visade inga tydliga felmeddelanden i gränssnittet.
- Önskemål framkom om stöd för periodsbokningar då hantering av flera separata bokningar upplevdes som tidskrävande.

Kunder

Positiva observationer

- Samtliga deltagare kunde genomföra bokningsprocessen utan hjälp.
- Produkterna upplevdes som enkla att hitta.

- Datumvalet upplevdes som intuitivt.
- Bokningsflödet kunde genomföras med få steg.

Identifierade problem

- Några användare efterfrågade tydligare bekräftelser efter genomförd bokning.
- Vissa deltagare upplevde att navigeringsmöjligheter saknades när de ville återgå till tidigare produktvyer.
- Enstaka deltagare uttryckte osäkerhet kring hur avbokningsfunktionen fungerade innan den användes.

C Appendix: Tematisk Analys

Tematisk analys

Efter intervjuerna genomfördes en tematisk analys där återkommande mönster identifierades och grupperades i teman.

Tema 1: Effektivitet i bokningsprocessen

Flera deltagare beskrev bokningsprocessen som enkel och effektiv. Uppgifterna kunde genomföras utan omfattande instruktioner och användarna upplevde att arbetsflödet var tydligt. Särskilt uppskattades att bokningar kunde genomföras med få steg och utan krav på kundkonto.

Tema 2: Tydlighet i gränssnittet

Deltagarna upplevde generellt att gränssnittet var lätt att förstå. Samtidigt framkom önskemål om tydligare återkoppling efter genomförda åtgärder.

Tema 3: Navigering

Majoriteten av deltagarna upplevde att det var enkelt att hitta mellan systemets olika funktioner. Vissa användare behövde dock längre tid för att lokalisera mindre frekvent använda funktioner.

Tema 4: Hantering av bokningar

De administrativa användarna lyfte fram värdet av att snabbt kunna söka fram och hantera bokningar. Samtidigt identifierades behov av stöd för periodsbokningar.

Tema 5: Övergripande användarupplevelse

Deltagarna beskrev systemet som modernt, lättanvänt och ändamålsenligt.

Identifierade förbättringsområden

- Tydligare återkoppling efter genomförda ändringar och bokningar.
- Förbättrad hantering och presentation av felmeddelanden från backend-systemet.
- Stöd för periodsbokningar över flera sammanhängande dagar.
- Tydligare navigeringsmöjligheter i det publika gränssnittet.
- Förbättrad visualisering av att ändringar sparats korrekt.